KARE HEALTH · ENGINEERING EXCELLENCE PROGRAMME

SDLC & DevSecOps Maturity Assessment



How the KareCare clinical records platform can ship safer software, faster.

Prepared for
Chief Technology Officer

Completed
17 February 2026 · v1.0

Design
Designed by Cynthia Agwaraonye

Leeds
Kare Health HQ, clinical records software since 2011

Nov–Jan
fieldwork, 3 Nov 2025 – 23 Jan 2026

CONTENTS

Inside this report

01	Executive summary	03
02	Method	04
03	Maturity scorecard	05
04	Delivery performance	06
05	Findings	07
06	Where the time goes	09
07	Target-state secure SDLC	10
08	Recommendations & roadmap	11
—	Glossary & credits	13

31
NHS & independent providers

4.6M
patient records

64
code repositories

Class I
medical device · UK MDR 2002

Kare Health is a fictional organisation. All names, metrics and findings are illustrative, created for a portfolio case study.

01

2.4 → 3.5
maturity target, December 2026

8
recommendations in three horizons

EXECUTIVE SUMMARY

Strong engineers, slowed by a lifecycle built for annual releases

Code quality is good. Time and risk build up after the merge: in manual regression, environment queues and a weekly change board.

2.4/5	47 d	22%	37%
overall maturity	median lead time	change failure rate	flow efficiency

Three findings

1. **Verification is the bottleneck**
   92% manual regression; 61% of P1/P2 from integration
2. **Traceability is late and manual**
   ≈ 60 person-hours of rework per release
3. **Security sits outside the pipeline**
   SAST on 14 of 64 repos; no SBOM

Three moves

- **Automate verification**
  70% regression automated by Q4
- **Generate evidence in the pipeline**
  traceability + SBOM per build
- **Approve by risk, not by meeting**
  low-risk changes auto-approve

< 10 days	< 12%	£640k
lead time by Dec 2026	change failure rate	cost vs £1.1m capacity released

02

Azure
UK South primary, UK West DR

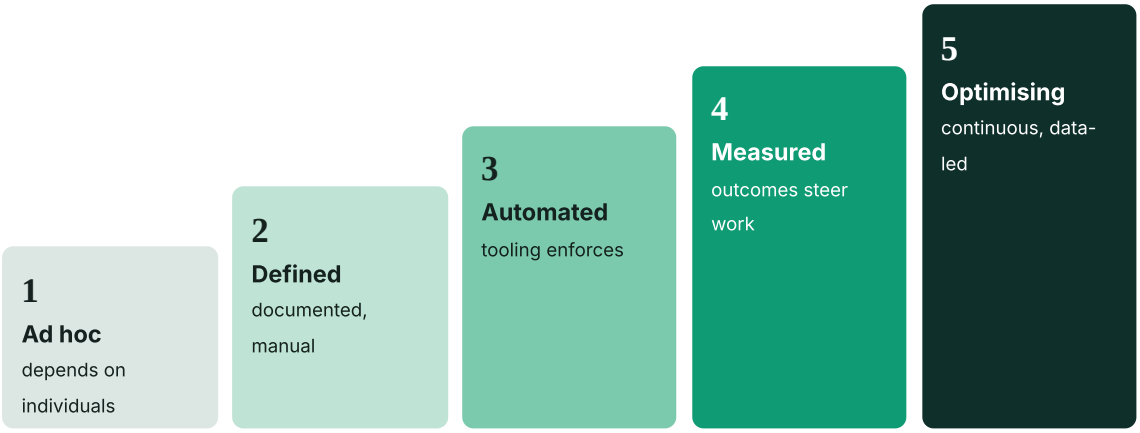
IEC 62304
software life-cycle standard applied

METHOD

Three evidence sources, eight dimensions, one scale

38	64	6 months	2 sources	Calibrated
interviews & workshops	repositories analysed	pipeline & incident telemetry	minimum per score	with leads, 20–21 Jan 2026

Maturity scale



Level 4 is the target for every dimension, matching peers that ship regulated clinical software weekly.

Frameworks

DORA · OWASP SAMM 2.0 · IEC 62304 life-cycle processes

In scope

EPR, e-prescribing, decision support, patient portal, HL7/FHIR integration engine

Out of scope

Corporate IT, legacy reporting suite, third-party pathology interfaces

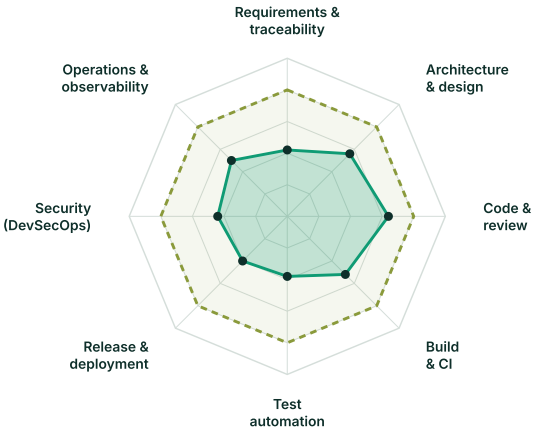
03

2.4
overall mean score

−1.6
average gap to level 4

MATURITY SCORECARD

Code is strong; testing and release lag furthest

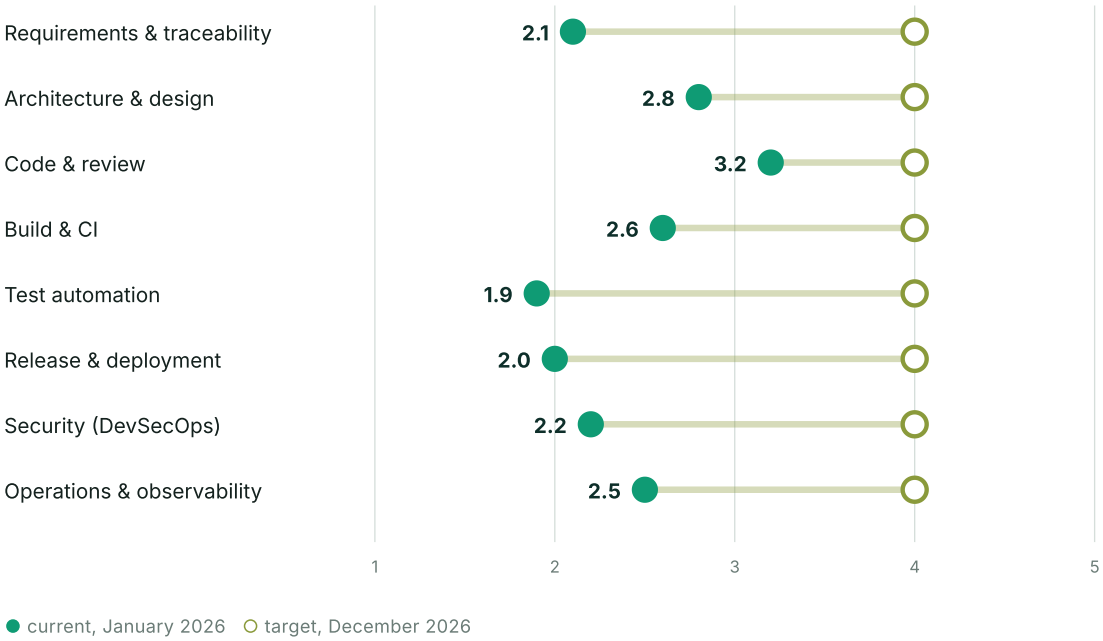


The three weakest dimensions all sit between merged code and a validated release.

1.9
Test automation, the lowest score

3.2
Code & review, the strongest

Current vs target by dimension



04

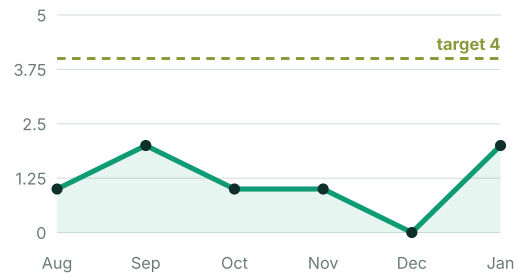
Aug–Jan
rolling telemetry window

212
production changes in the period

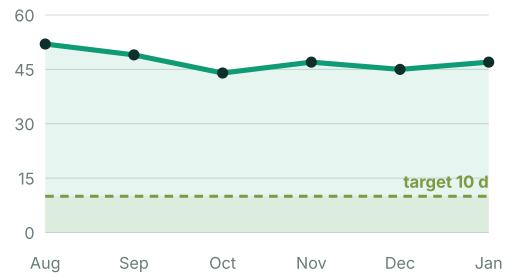
DELIVERY PERFORMANCE · DORA

All four DORA measures sit in the low band

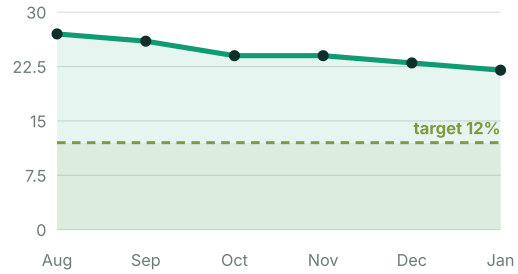
Deployment frequency / month



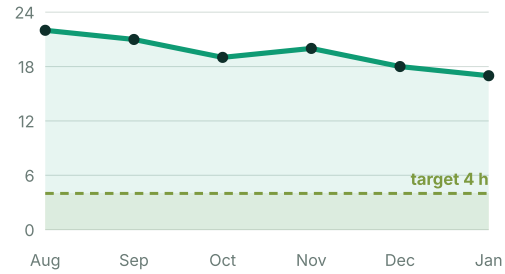
Lead time median days



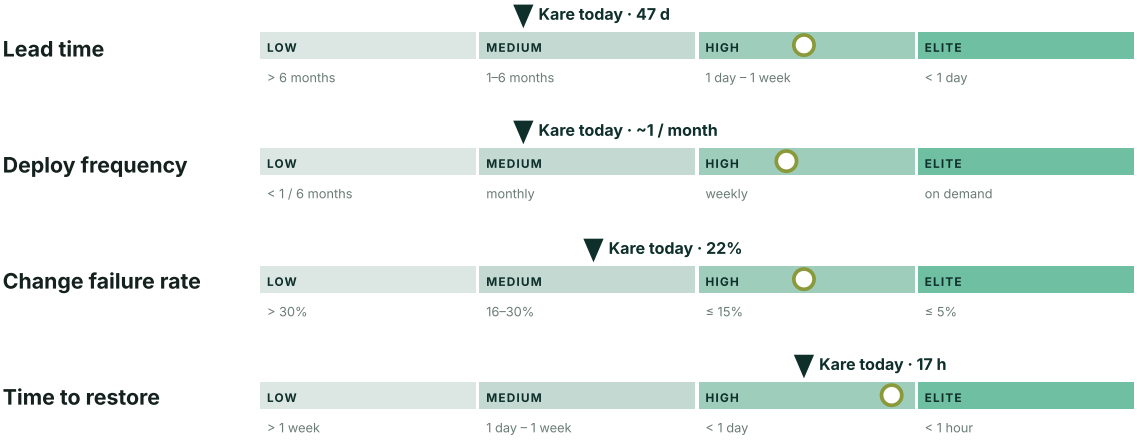
Change failure rate %



Time to restore median hours



Where Kare sits against DORA benchmark bands



▼ Kare today ○ December 2026 target. December dip reflects the NHS winter change freeze (15 Dec – 5 Jan).

05

6 of 12
high-severity findings

3
of them in test & release

FINDINGS · OVERVIEW

Twelve findings, concentrated in test and release

Findings by lifecycle phase and severity

	High	Medium	Low
Requirements & design	1	1	
Build & code		1	1
Test & verification	2	1	
Release & deployment	1	1	
Security & compliance	1	1	
Operations		1	

6
high

5
medium

1
low (a strength)

Finding index

F-01	Hazard-to-test traceability rebuilt manually	High
F-02	NFRs rarely specified (11 of 142 epics)	Medium
F-03	Peer review consistent and effective	Low
F-04	41 bespoke pipeline definitions	Medium
F-05	Regression 92% manual	High
F-06	Integration defects escape	High
F-07	Shared, queued test environments	Medium
F-08	CAB reviews every change equally	High
F-09	Manual deploy and rollback	High
F-10	Security testing outside delivery	High
F-11	Ad hoc threat modelling	Medium
F-12	Infrastructure-only monitoring	Medium

05

Integration
the most common incident root cause

−18 days
lead-time saving from removing two queues

FINDINGS · THE SIX HIGH-SEVERITY ISSUES

The evidence in six numbers

F-05

92%

of regression is manual

1,860 cases, 5 working days per release

F-06

61%

of P1/P2 incidents from integration faults

HL7 v2 / FHIR and service-contract changes

F-08

96%

of CAB reviews change nothing

212 changes, 5-day average wait

F-10

14 / 64

repositories run SAST

no SBOM for any release

F-01

9%

of hazard mitigations lack a test

traceability rebuilt in Excel each release

F-09

17 h

median time to restore

manual rollback, database restore required

Strengths to retain

Universal peer review (F-03) · empowered clinical safety team · modular service boundaries · 80% of Azure resources in Bicep.

06

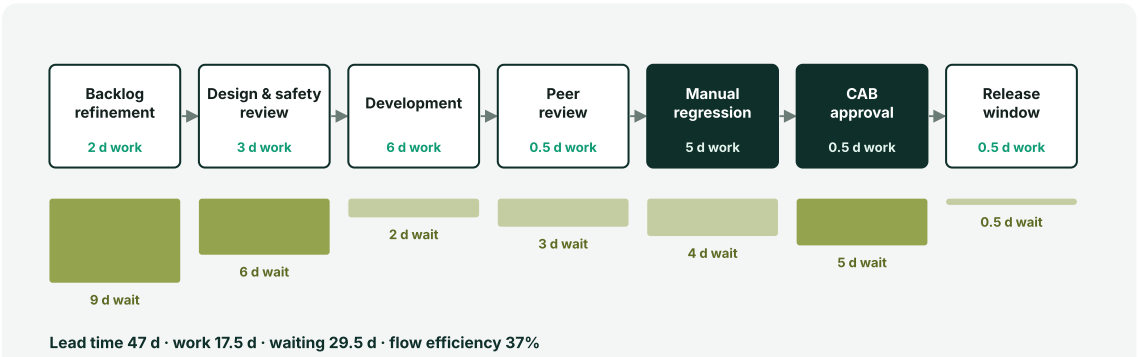
37%
flow efficiency today

> 60%
target flow efficiency

VALUE STREAM

Of 47 days lead time, 29.5 are spent waiting

38 changes traced from refined backlog item to production, September–December 2025.



Boxes: median work per step. Olive bars: median wait before the next step. Dark boxes are the two removable queues.

9 d
backlog wait, the largest single queue

9 d
manual regression plus its queue

5 d
CAB wait, with no measurable risk reduction

Faster coding would barely move lead time.

Removing the regression and CAB queues recovers ≈ 18 days. Running safety review in parallel with development recovers 6 more.

07

IEC 62304
§5.1, §5.7 evidenced per release

DCB0129
hazard log linked to tests

TARGET-STATE SECURE SDLC

Evidence produced as the work happens



Regulatory traceability chain

Requirement — Jira epic / story → **Hazard** — DCB0129 log entry → **Test** — Xray automated case → **Build** — signed artefact + SBOM → **Release** — Git tag + CSO approval

Red gate if any link is missing · exported per release for IEC 62304 audit

Risk-tiered release approval

Low
No hazard impact, all gates green
→ automatic

Medium
Touches a mitigation or integration contract
→ CSO in pull request

High
New clinical function or data flow
→ safety case + CSO + CTO

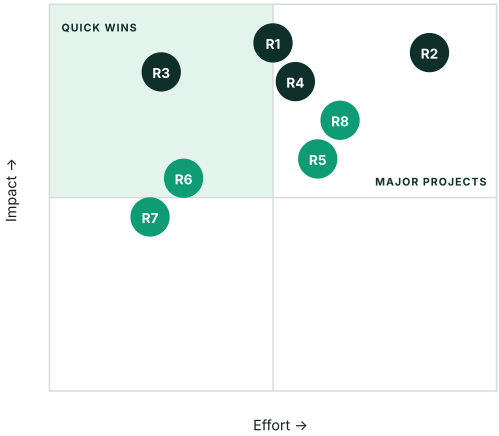
08

R3
highest impact for lowest effort

R2
largest programme, 70% automation

RECOMMENDATIONS

Eight recommendations, sequenced by impact and effort



Dark: high impact (≥ 3). Mint quadrant: quick wins.

R1	Standard pipeline templates with SAST, secrets scan and SBOM	Q2
R2	Automate 70% of regression, hazard-linked cases first	Q2–Q4
R3	Risk-tiered approval replaces the weekly CAB	Q3
R4	One traceability graph: Jira + Xray + Git tags	Q2–Q3
R5	Ephemeral test environment per pull request	Q2–Q3
R6	SLOs and error budgets for patient-facing services	Q3
R7	Threat model every epic touching patient data	Q2
R8	Weekly release train with feature flags	Q4

Horizon 1 · Q2
R1 · R4 · R5 · R7: pipelines, traceability, environments

Horizon 2 · Q3
R2 · R3 · R6: automation at scale, risk-tiered approval, SLOs

Horizon 3 · Q4
R8: weekly release train with feature flags

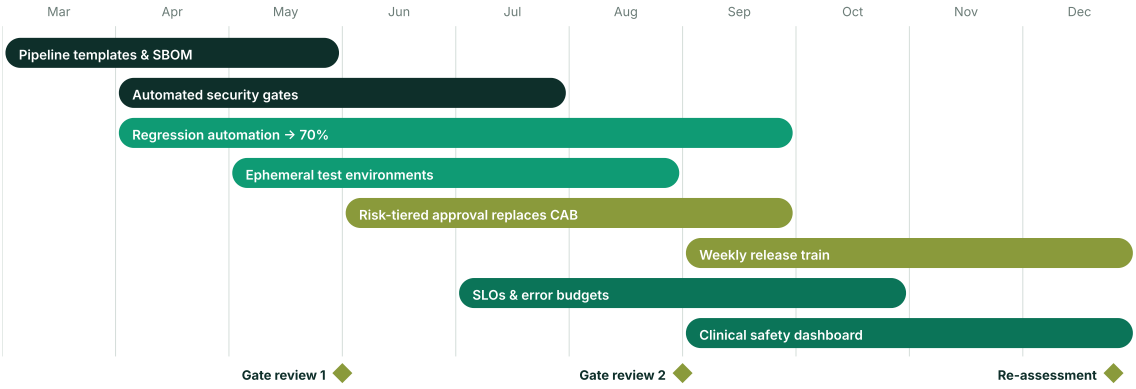
08

Mar–Dec
2026 delivery window

3
gate reviews

2026 ROADMAP & TARGETS

Ten months to a weekly, evidence-ready release



< 10 d
lead time

< 12%
change failure rate

< 4 h
time to restore

3.5
overall maturity

Governance

Monthly steering with CTO and Clinical Safety Officer. DORA and maturity metrics reported from the pipeline, not from surveys.

Re-assessment

December 2026, same method and evidence thresholds, so progress is comparable.

GLOSSARY & CREDITS

Glossary

v1.0
final, February 2026

CAB Change Advisory Board

CSO Clinical Safety Officer, accountable under DCB0129

DAST / SAST dynamic / static application security testing

DCB0129 NHS clinical risk standard for health IT manufacturers

DORA four key measures of software delivery performance

DSPT NHS Data Security and Protection Toolkit

DTAC Digital Technology Assessment Criteria

FHIR / HL7 v2 healthcare data interchange standards

Flow efficiency work time as a share of lead time

IEC 62304 medical device software life-cycle standard

SBOM software bill of materials

SLO service-level objective

CLIENT

Kare Health Ltd
Engineering Excellence Programme
Leeds, United Kingdom

DOCUMENT

SDLC & DevSecOps Maturity Assessment
Version 1.0 · completed 17 February 2026

DESIGN

Designed by Cynthia Agwaraonye
Editorial & information design

Fictional client and illustrative data, prepared as a portfolio case study. Set in Bitstream Charter and Inter.